

Simtec Consult - Incident Response and Personal Data Breach Plan

Version: 1.1

Status: Approved

Owner: Director

Applies to: employees, contractors, company systems, customer systems administered by Simtec, personal data handled by Simtec

Related to: Cyber Essentials, UK GDPR, Data Protection Act 2018

Last reviewed: 2026-07-03

Next review due: 2026-10-03

Purpose

This plan defines how Simtec identifies, contains, investigates, recovers from, and learns from cyber security incidents and personal data breaches.

What To Report

Staff and contractors must report suspected incidents promptly to a Director. Reportable events include lost or stolen work devices, suspected account compromise, unexpected MFA prompts, malware, exposed secrets or SSH keys, client data sent to the wrong recipient, unauthorised access, exposed private repositories or databases, critical vulnerabilities, backup failures affecting recovery, and supplier breaches affecting Simtec or customer data.

Severity

Severity	Description	Examples
Critical	Active compromise, major customer impact, high-risk personal data breach, or loss of core services.	Ransomware, production data exfiltration, administrator account takeover.
High	Material risk requiring urgent containment but limited confirmed impact.	Leaked deployment key, exploited server vulnerability, lost device with client data.
Medium	Security event needing investigation and remediation.	Phishing click without confirmed compromise, suspicious login blocked by MFA.
Low	Minor event or near miss.	Spam, failed login noise, misconfiguration caught before exposure.

Response Process

The Director or nominated responder must triage the incident by recording the date and time, identifying affected systems, users, customers and data, assigning severity, preserving evidence, and deciding immediate containment actions.

Containment may include resetting passwords, revoking sessions and tokens, disabling accounts, removing public access, blocking IP addresses or firewall rules, isolating affected servers or devices, pausing deployments, and contacting suppliers or customers.

Investigation should establish what happened, when it started and was detected, affected systems and data, whether personal data was involved, whether customer, ICO, NCSC, police, insurer, or contractual notification is required, root cause, and corrective actions.

Recovery may include restoring from clean backups, rebuilding servers or services, applying vulnerability fixes, rotating secrets, re-enabling access only after checks, monitoring for recurrence, and confirming customer-facing services are working.

After a material incident, Simtec must record timeline, impact, root cause, actions taken, notifications made, preventive improvements, and any policy or control changes needed.

Personal Data Breach Assessment

A personal data breach is a security incident causing accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data.

For suspected personal data breaches, Simtec must assess the type and volume of personal data, number and type of affected people, sensitivity, whether data was encrypted or otherwise protected, likely harm, and whether affected people need advice or support.

If a breach is likely to result in a risk to people's rights and freedoms, Simtec must report it to the ICO without undue delay and, where feasible, within 72 hours of becoming aware of it. If the breach is likely to result in a high risk to affected people, Simtec must inform them without undue delay. Decisions not to report must be documented.

Where Simtec processes personal data for a customer/controller, Simtec must notify that customer/controller without undue delay after becoming aware of a personal data breach affecting that data, so the customer can meet its own legal and contractual duties.

Incident Records

Simtec must keep an incident and breach log recording reference number, date/time reported, reporter, severity, affected systems or suppliers, data affected, actions taken, notification decisions, owner, closure date, and lessons learned.

Review

This plan is reviewed annually and after significant incidents, personal data breaches, or near misses.

Review History

Date	Reviewer	Description	Next review due
2026-07-03	Policy Manager	Added processor-to-controller breach notification because the weekly review found a material gap for customer systems and personal data handled as processor.	2026-10-03
2026-06-03	Policy Manager	Created current policy document aligned to Simtec requirements and relevant Cyber Essentials answers.	2026-09-03